

HW06 – Báo cáo Kiểm thử API

Sinh viên: Hà Bảo Ngọc — 23127300, nhóm N08 **Môn học:** CS423 / CSC15003 – Kiểm thử Phần mềm
Ngày nộp: 2026-08-20 **Nhánh:** HW06/23127300 **Repo:** <https://github.com/lmchkh/CS423-CSC15003-Testing-N08>

1. Tổng quan

Báo cáo ghi lại pipeline kiểm thử API cho ba API của hệ thống EShop:

Pool	FR	Endpoint	Lý do chọn
A	FR-01	POST /api/register	Tham số phong phú (name/email/password); oracle rõ ràng; surface bảo mật (SQL, password exposure)
B	FR-08	POST /api/checkout	Giao dịch yêu cầu auth; mô hình trạng thái FR-10; IDOR qua /api/orders/:id
C	FR-14	GET/POST/PUT/DELETE /api/categories	CRUD lifecycle; broken access control; missing-resource contract

Kết quả tổng hợp:

API	Cases thiết kế (AI+SV)	Newman assertions	Pass	Fail	Bugs
FR-01 Register	45 (40+5)	45	45	0	3
FR-08 Checkout	40 (35+5)	76	76	0	3
FR-14 Category	47 (40+7)	112	112	0	4
TOTAL	132	233	233	0	10

Suite chạy **xanh**: assertion của case known-bug kiểm hành vi quan sát được của SUT (gắn nhãn [BUG-*]); 10 lệch chuẩn được đếm ở cột Bugs và mô tả expected-vs-actual bên dưới.

2. Anti-cheat — Header X-Student-Id

Mọi request trong collection đều mang header X-Student-Id: 23127300 thông qua pre-request script ở cấp collection:

```
// Collection-level pre-request script
pm.request.headers.upsert({ key: 'X-Student-Id', value: '23127300' });
console.log('[HW06] X-Student-Id =', '23127300', '→', pm.request.url.toString());
```

Bằng chứng: file `reports/hw06-auth-bootstrap-evidence.log` ghi lại console output của Newman khi chạy folder `FR-08 State & Security`, xác nhận dòng `[HW06] X-Student-Id = 23127300` xuất hiện trong **mọi** request tại `localhost:3000` (11/11 assertion pass). Chạy lại bất kỳ folder nào cũng in dòng này vì script nằm ở cấp collection.

3. Pipeline từng API

3.1 FR-01 `POST /api/register`

Bước 1: AI-generate (step-by-step)

Sử dụng 4 prompt riêng biệt (xem `reports/prompt-log.md`): 1. Phân vùng tham số `name` → 8 cases (TC-FR01-001–008) 2. Phân vùng tham số `email` → 14 cases (TC-FR01-009–022) 3. Phân vùng tham số `password` → 10 cases (TC-FR01-023–032) 4. Schema + bảo mật + trạng thái → 8 cases (TC-FR01-033–040)

Tổng: **40 cases** (`test-cases/FR-01-register/ai-generated.md`)

Bước 2: Audit

Kết quả audit (`test-cases/FR-01-register/audit.md`): - **VALID**: 28 cases — oracle đúng per spec và SUT behaviour - **INVALID**: 3 cases — AI giả định SUT có validation nhưng thực tế không có (email trùng → 409, mật khẩu yếu → 400); đã sửa oracle thành `knownBug: true` - **INCOMPLETE**: 9 cases — thiếu assertion schema hoặc precondition

Lỗi điển hình của AI: giả sử SUT có ràng buộc UNIQUE trên email (không có), giả sử có kiểm tra độ phức tạp mật khẩu (không có).

Bước 3: Extend — 5 cases sinh viên

File: `test-cases/FR-01-register/extended.md`

ID	Mô tả	Lý do AI bỏ qua
TC-EX-001	Email trùng được chấp nhận → 200 (bug)	AI giả định có ràng buộc UNIQUE
TC-EX-002	Body rỗng <code>{}</code> → insert dòng NULL (200)	AI giả định có kiểm tra field bắt buộc
TC-EX-003	<code>/api/login</code> và <code>/api/users/me</code> trả về trường <code>password</code> plaintext	AI không đi theo chuỗi auth
TC-EX-004	Mật khẩu yếu <code>123</code> được chấp nhận → 200 (bug)	AI giả định có kiểm tra độ phức tạp
TC-EX-005	Email chỉ có khoảng trắng được chấp nhận → 200 (bug)	AI giả định có kiểm tra định dạng email

Bước 4–6: Thực thi Newman

Data file: `api/data/register-cases.json` (45 rows) Newman command: `bash api/scripts/run-api.sh "FR-01 Register" api/data/register-cases.json api/newman/fr01-register-report` hoặc `bash api/scripts/run-all.sh` Report: `api/newman/fr01-register-report.html`

Kết quả: FR-01 Register — 45 assertions, 45 pass, 0 fail (data-driven, `register-cases.json`). 3 bug được ghi ở §2.4.

Bước 7: Bug reports

Bug ID	Mô tả	Severity
BUG-FR01-001	Email trùng được chấp nhận (không có ràng buộc duy nhất)	Major
BUG-FR01-002	Không kiểm tra dữ liệu đầu vào (mật khẩu rỗng/yếu vẫn được nhận)	Major
BUG-FR01-003	<code>/api/login</code> và <code>/api/users/me</code> trả về trường <code>password</code> plaintext	Critical

Issues: #252, #253, #254 trên GitHub.

3.2 FR-08 POST `/api/checkout`

Bước 1: AI-generate

Sử dụng prompt phân vùng `total_amount` (8 cases), `shipping_address` (5 cases), auth partition (3 cases), state-machine FR-10 (10 cases), IDOR (2 cases), schema (3 cases) → **35+ cases** (`test-cases/FR-08-checkout/ai-generated.md`).

Bước 2: Audit

- **INVALID:** AI giả định `total_amount <= 0` bị reject (thực tế SUT chấp nhận); AI giả định `GET /api/orders/:id` yêu cầu auth (thực tế không có); AI bỏ qua chuyển trạng thái bất hợp lệ `canceled-delivered`.

Bước 3: Extend — 5 cases sinh viên

ID	Mô tả	Lý do AI bỏ qua
TC-FR08-EXT-001	IDOR: <code>GET /api/orders/:id</code> không cần token → 200 (bug)	AI giả định endpoint luôn yêu cầu auth
TC-FR08-EXT-002	<code>total_amount</code> âm được chấp nhận → 200 (bug)	AI giả định có kiểm tra dữ liệu đầu vào
TC-FR08-EXT-003	Chuyển trạng thái sai luật <code>canceled-delivered</code> được chấp nhận → 200 (bug)	AI không mô hình hóa trạng thái kết thúc
TC-FR08-EXT-004	Checkout với empty body → 500 (unexpected error)	AI không test edge body
TC-FR08-EXT-005	String <code>total_amount</code> "abc" → coerced to 0 or 500	AI không test type coercion

Bước 4–6: Thực thi Newman

Data file: `api/data/checkout-cases.json` (15 rows) + non-data-driven state machine requests Newman command: `bash api/scripts/run-fr08.sh` Report: `api/newman/fr08-checkout-report.html`

Kết quả: FR-08 — folder Checkout (data-driven) 65 assertions + folder State & Security 11 assertions = **76 pass, 0 fail**. Case known-bug (total_amount không validate, IDOR, canceled→delivered) assert hành vi quan sát, gắn nhãn [BUG-*] .

Bước 7: Bug reports

Bug ID	Mô tả	Severity
BUG-FR08-001	IDOR: GET /api/orders/:id không yêu cầu auth	Critical
BUG-FR08-002	Không kiểm tra total_amount (giá trị âm vẫn được nhận)	High
BUG-FR08-003	Chuyển trạng thái sai luật canceled→delivered vẫn được chấp nhận	High

Issues: #255, #256, #257 trên GitHub.

3.3 FR-14 GET/POST/PUT/DELETE /api/categories

Bước 1: AI-generate

Phân vùng name (10 cases), kiểm soát truy cập (3 cases), lifecycle CRUD (5 cases), hợp đồng resource không tồn tại (4 cases), schema (4 cases), bảo mật (4 cases) → **≥35 cases** (test-cases/FR-14-category/ai-generated.md).

Bước 2: Audit

- **INVALID:** AI giả định có middleware kiểm tra role admin (thực tế authenticateToken chỉ check token, không check role); AI giả định PUT/DELETE ID không tồn tại → 404 (SUT trả 200).

Bước 3: Extend — 5 cases sinh viên

ID	Mô tả	Lý do AI bỏ qua
TC-FR14-041	User thường tạo danh mục → 200 (bug leo thang quyền)	AI giả định có RBAC
TC-FR14-042	User thường xóa danh mục → 200 (bug leo thang quyền)	AI giả định có RBAC
TC-FR14-043	PUT /api/categories/999999 → 200 (không 404)	AI giả định backend có kiểm tra affectedRows
TC-FR14-044	DELETE /api/categories/999999 → 200 (không 404)	AI giả định backend có kiểm tra affectedRows
TC-FR14-045	Tên danh mục trùng được chấp nhận → 200 (không 409)	AI giả định có ràng buộc UNIQUE
TC-FR14-046	Tên danh mục rỗng được chấp nhận → 200	AI giả định có kiểm tra input
TC-FR14-047	Tên danh mục chỉ có khoảng trắng được chấp nhận → 200	AI giả định có trim và kiểm tra input

Bước 4–6: Thực thi Newman

Data file: api/data/fr14-post-categories.csv (17 rows) Newman command: bash api/scripts/run-fr14.sh Báo cáo: api/newman/fr14-category-report.html

Kết quả: FR-14 — folder Category CRUD (data-driven) 95 assertions + folder Lifecycle & Access 17 assertions = **112 pass, 0 fail**. Các lỗi phân quyền, thiếu kiểm tra 404 cho resource không tồn tại, tên trùng

và tên rỗng đều assert theo hành vi quan sát được + gắn nhãn `[BUG-*`] .

Bước 7: Bug reports

Bug ID	Mô tả	Severity
BUG-FR14-001	Lỗi phân quyền: user thường CRUD được danh mục	Critical
BUG-FR14-002	PUT/DELETE ID không tồn tại vẫn trả 200 (không 404)	Medium
BUG-FR14-003	Tên danh mục trùng được chấp nhận (không có ràng buộc duy nhất)	Low
BUG-FR14-004	Tên danh mục rỗng/chỉ có khoảng trắng được chấp nhận	Medium

4. Tính năng Postman sử dụng

Tính năng	Mô tả sử dụng
Collection & Folders	1 collection, 5 folders thực thi: FR-01 Register, FR-08 Checkout, FR-08 State & Security, FR-14 Category CRUD, FR-14 Lifecycle & Access
Environment	<code>local.postman_environment.json</code> : <code>baseUrl</code> , <code>studentId</code> , <code>userToken</code> , <code>adminToken</code> , <code>lastOrderId</code> , <code>lastCategoryId</code>
Collection-level pre-request script	Upsert <code>X-Student-Id</code> : <code>23127300</code> vào mọi request (anti-cheat §11)
Folder-level pre-request script	Build dynamic request body từ iteration data
Test scripts (<code>pm.test</code>)	Assert status code, schema, known-bug pattern
Dynamic variables	<code>{{timestamp}}</code> , <code>{{guid}}</code> để generate unique emails
Data-driven Collection Runner	<code>-d register-cases.json</code> , <code>-d checkout-cases.json</code> , <code>-d fr14-post-categories.csv</code>
Newman CLI	<code>newman run ... -r cli,htmlextra</code> headless execution
<code>newman-reporter-htmlextra</code>	HTML report với request/response logs, failure highlights
Chained requests	Request đăng ký/đăng nhập trong từng folder state/lifecycle capture token rồi truyền sang request sau
Environment variable setters	<code>pm.environment.set('userToken', ...)</code> để pass state giữa requests
CI runner / repeatable CLI	<code>run-all.sh</code> và GitHub Actions chạy lại cùng bộ Newman trên SUT local/headless

5. Mapping phạm vi kiểm thử

FR	Spec section	Endpoints	Covered by
FR-01	§1.1 User Registration	<code>POST /api/register</code>	Task 3, collection folder "FR-01 Register"

FR	Spec section	Endpoints	Covered by
FR-08	API spec §4.3 Checkout	POST /api/checkout	Task 4, collection folder "FR-08 Checkout"
FR-10	API spec §6.2 Order Status	PUT /api/admin/orders/:id/status	Task 4 (state machine cases)
FR-14	API spec §3.4 Category Management	GET/POST/PUT/DELETE /api/categories	Task 5, collection folders "FR-14 Category CRUD" và "FR-14 Lifecycle & Access"

6. Artifacts

Artifact	Đường dẫn
Postman collection	api/collections/eshop-hw06.postman_collection.json
Environment	api/environments/local.postman_environment.json
Data files	api/data/register-cases.json, checkout-cases.json, fr14-post-categories.csv
Newman HTML reports	api/newman/fr01-register-report.html, fr08-checkout-report.html, fr08-state-report.html, fr14-category-report.html, fr14-lifecycle-report.html
Test cases (MD)	test-cases/FR-{01,08,14}-*/ai-generated.md, audit.md, extended.md; split files in tests/test-cases/FR-{01,08,14}-*/TC-*.md
Test summary	test-cases/test-summary.xlsx (132 cases thiết kế, 233 assertions, 10 bugs)
Bug reports	bug-reports/BUG-FR{01,08,14}-*.md
CI/CD	.github/workflows/hw06-newman.yml, reports/ci-cd-report.md
Agent Skill	.claude/skills/api-test-generator/SKILL.md
Design diagram	diagrams/test-generator.png (tự vẽ), nguồn diagrams/test-generator.drawio, bản Mermaid diagrams/test-generator.md, pseudocode diagrams/test-generator.py; pseudocode tóm tắt cũng nằm trong reports/test-generator-design.md